COLORADO
Information Security
Governor's Office of Information Technology

TS-CISO-004: OIT Firewall Design Standard

Document ID	TS-CISO-004
Title	OIT Firewall Design Standard
Executive Sponsor	Jill Fraser, Chief Information Security Officer
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	All firewalls under OIT control, or under the control of any provider of IT services to a state agency; used by employees of OIT, agencies supported by OIT, and vendors contracted by OIT or its stakeholders.
Instrument Type	Standard
Version	3.0
Effective Date	03/17/2016
Last Updated	09/15/2025

1. Purpose

The purpose of an Enterprise Firewall Design Standard is to enable an efficient and effective design and implementation of firewalls while providing the desired secure access and data sharing between all business partners. Adoption of this standard will expedite the Firewall Change Request (FCR) lifecycle from request, approval, implementation, and testing.

OIT is statutorily obligated and authorized (§ 24-37.5 C.R.S.) to provide IT support and services to the State and its stakeholders in the most effective and efficient manner possible. This standard is created in general support of this and the specific purposes stated above.

2. Scope

The Enterprise Firewall Design Standard applies to all firewalls that are under OIT control or any provider of IT services to a/any state agency. These standards apply to OIT and OIT-supported agencies, and shall be used by employees of OIT, agencies supported by OIT, and vendors contracted by OIT or its stakeholders as a means to enforce technology standardization and assist in making the usage, support, and/or purchase of technologies more consistent and efficient.

3. Roles and Responsibilities

Enterprise Architecture - Chief Enterprise Architect

- Chairs and conducts business of the Architecture Review Board (ARB).
- Updates effective date and/or last review date.
- Publishes the ARB-approved Standard to the OIT public-facing website.

Architecture Review Board (ARB)

- Engages stakeholders and subject matter experts to determine the standard.
- Reviews/approves the Standard (this document).

Chief Information Security Office - Enterprise Security Architect

- Owner of Standard.
- Engages stakeholders and subject matter experts to determine the standard.
- Updates document standards and version number.
- Presents to the Architecture Review Board for approval and adoption.

4. Standards

Architecture Diagram

The high-level architecture identifies the potential choke points where a firewall must be put in place, and a positive (whitelisting) firewall policy must be implemented to support a secure, business-enabling flow of traffic between different zones (domains).

Traffic Access Requirements

Common Requirements:

- Firewall implementation and operation must enable business functions while ensuring business compliance and achieving protection needs.
- All access (cross-boundary) must be based on business needs.
- Implement and enforce firewall Positive Policy and Whitelisting concepts.
- Use defined standard ports and protocols.
- Deviation from standard ports and protocols must be supported by vendor documentation.
- Custom ports and protocols must be reviewed and approved by the Security Architecture team.
- Use encrypted versions of services; deviation must be reviewed and approved by the Security Architecture team.

Perimeter Traffic — To the Internet:

- All outbound connections from servers must be NAT'd.
- Direct access to the Internet from servers in the trusted network is prohibited.
- Access to the Internet from servers in the trusted network must be reviewed and approved by the Security Architecture team.

Perimeter Traffic — From the Internet:

- All inbound traffic must be terminated in a DMZ.
- All inbound traffic from the Internet to servers in the trusted network must be reviewed and approved by the Security Architecture team.

DataCenter Traffic:

- To DataCenter: All traffic allowed to an agency data center must originate in the agency's DMZ or VRF; direct inbound access must be reviewed and approved by the Security Architecture team.
- Out of DataCenter: All outbound traffic from an agency's data center must be approved by the Security Architecture team.

- Intra-DataCenter: All traffic between zones within the DataCenter must be approved by the Security Architecture team, except traffic specifically allowed by this standard.
- Inter-DataCenter: All traffic between one agency's data center and another's must be approved by the Security Architecture team, except traffic specifically allowed by this standard.

Agency Traffic:

- To the Agency: All traffic from the Internet to the agency's user VLANs must be approved by the Security Architecture team, except traffic specifically allowed by this standard.
- From the Agency: All outbound traffic must be explicitly authorized (otherwise denied), and all source addresses must be masqueraded/NAT'd.
- Inter-Agency: All traffic between one agency's data center and another's must be approved by the Security Architecture team, except traffic specifically allowed by this standard.

DMZ Traffic:

- To the Internet / From the Internet: All outbound/inbound traffic to or from a DMZ must be approved by the Security Architecture team, except traffic specifically allowed by this standard.
- To the Trusted Network: All inbound traffic from a DMZ to the Trusted Network must be approved by the Security Architecture team, except traffic specifically allowed by this standard. The trusted link VLAN is protected and should only allow outbound traffic behind the agency firewall hide-NAT; no DMZ traffic should be allowed into the Trusted Link.

3rd-Party Service Provider Traffic:

- All traffic to/from the Internet, and to/from the State Network, involving a 3rd-party service provider must be approved by the Security Architecture team, except traffic specifically allowed by this standard.

Standard (Pre-Approved) Ports and Protocols

The Standard (Pre-Approved) Ports and Protocol table below is maintained and updated by the Security Architecture Team. Entries/updates come from the outputs of the Firewall Change Request process as qualified standard changes; empty and/or incomplete cells are updated periodically. An asterisk (*) denotes a custom pre-approved port/protocol path reviewed case-by-case.

Service: Protocol / Port	Perimeter	DataCenter	Agency	Provider / Partner
Web Based: TCP 443, TCP 8443*, TCP 80, TCP 8080*	Internet ↔ DMZ	—	User VLANs ↔ Agency Resource VLANs	User VLANs ↔ Provider/Partner
Remote Support: ICMP	—	Intra Data Center ↔ Agency	Data Center ↔ Agency	*
Active Directory: LDAP TCP/UDP 389, Kerberos TCP/UDP 88, LDAPS (SSL) TCP 636, LDAP GC TCP 3268, LDAP GC SSL TCP	—	User VLANs ↔ Data Center	Agency ↔ Data Center	*

Service: Protocol / Port	Perimeter	DataCenter	Agency	Provider / Partner
3269, Kerberos Password Change/Set TCP/UDP 464				
File Transfer: SFTP TCP 22, FTPS TCP 992	Internet ↔ DMZ	Data Center ↔ Data Center	User VLANs ↔ Data Center	*
Terminal Services: RDP TCP/UDP 3389, RDPS TCP 443	—	—	Agency ↔ Data Center	*
VPN: SSL (SSTP TCP 443), IPsec (PPTP TCP 1723, L2TP UDP 500/4500, IKEv2 UDP 500/4500)	—	Internet ↔ Data Center; Data Center ↔ Data Center	*	Data Center ↔ Provider/Partner
Network Management: SNMP v3 UDP 161/162, SSHv2 TCP 22, Syslog UDP 514, NTP UDP 123, DHCP TCP/UDP 67/68	—	NTP: Data Center ↔ Trusted Time Source; SSHv2 & Syslog: Agency ↔ Data Center	Terminal Emulation ↔ Agency ↔ Data Center	*
VMware – vRealize Ops Mgr (SSH TCP 22, HTTP TCP 80/443, NTP UDP 123, xDB TCP 1235, V4V TCP 3091–3094, and related service ports)	—	Intra Data Center ↔ Data Center	Data Center ↔ Agency	*
VMware – vRealize Config Mgr (FTP, DNS, DHCP, TFTP, HTTP/S, Kerberos, NTP, RPC, NetBIOS, SNMP, LDAP/S, MSSQL, RDP, and related management ports)	—	Intra Data Center ↔ Data Center	*	*
Messaging Protocols: SMTP TCP 25, IMAP TCP 143, IMAPS TCP 993	*	*	*	*
Database Management Services: MS SQL TCP 1433, Informix TCP 1526, Oracle TCP 1620	*	DMZ ↔ Resource VLAN in Data Center	*	*
Domain Name Service: DNS Zone Transfer TCP 53, DNS Name Resolution UDP 53	*	*	Agency ↔ Data Center (UDP)	*
Windows NetBIOS: Name Resolution UDP 137, Datagram Svc UDP 138, Session Svc TCP 139	*	*	Data Center ↔ Agency	*
Windows File Service: SMB/CIFS TCP 445	*	*	Data Center ↔ Agency	*

5. Variance and Exception Process

All deviations from this standard must be documented following the Secure Configuration Exception Request process; a template for the Exception Request is available on Google Drive. The process addresses business or technical reasons for the inability to adhere to one or more requirements in this standard; requests should include compensating controls — processes, technologies, or procedures used to mitigate any deviation.

The Secure Configuration Exception Request form must be submitted to the Office of Information Security at OIT_CISO@state.co.us. For help completing the form, request assistance through the same mailbox. Exception requests will be processed and recommended for approval, conditional approval, or denial to the State Chief Information Security Officer.

The Standard (Pre-Approved) Ports and Protocol table is maintained and updated by the Security Architecture Team; entries/updates come from the outputs of the Firewall Change Request process as qualified standard changes.

6. References

- C.R.S. 24-37.5: Colorado Revised Statutes, Title 24, Government - State Governor's Office, Article 37.5, Office of Information Technology
- Colorado Information Security Policies (CISPs)
- Payment Card Industry (PCI) Data Security Standard
- Firewall Change Request video
- Firewall Change Request Customer Portal
- Internet Engineering Task Force RFCs: 768, 783, 791-793, 816, 826, 854, 862-865, 867, 894, 919, 922, 950, 959, 1001, 1002, 1009, 1034, 1035, 1042, 1055, 1065, 1112, 1122, 1123, 1144, 1157, 1179, 1188, 1191, 1201, 1256, 1323, 1332, 1518, 1519, 1534, 1542, 1552, 1661, 1662, 1748, 1749, 1812, 1828, 1829, 1851, 1852, 1878, 1886, 1994–1996, 2018, 2085, 2104, 2131, 2136, 2181, 2236, 2308, 2401, 2402, 2406, and 2581.

7. Definitions

- 3rd-party Service Provider Traffic: Network traffic that flows between a 3rd-party service provider and the state network, irrespective of direction.
- App ID: Used to identify traffic application instead of port and protocols.
- Authorization: The action or fact of authorizing or being authorized, or a document giving permission or authority.
- Bidirectional Firewall Rule: A rule that allows either the source or the destination device to initiate the connection.
- DMZ Traffic: Network traffic originating from the state resource network or the Internet that connects to devices inside an isolated network protected from the Internet by a firewall, and isolated from the state resource and user networks by a second firewall.
- Exception Request: A document requesting an exception to a recognized standard, requiring a business or technical justification, subject to review and approval by an authority in the area.
- Firewall: A network security system, hardware or software based, that controls incoming and outgoing network traffic based on a set of rules.
- Intra-Agency Traffic: Network traffic originating inside an agency's network and connecting to another device logically located inside the same agency's network.
- Intra-DataCenter Traffic: Network traffic confined to one of the state data centers.

- NAT: Network Address Translation — remapping IP addresses from one IP address space to another by modifying network address information in an IP packet header while in transit across a routing device, typically a firewall.
- Perimeter Traffic: Network traffic that crosses a network perimeter.
- Positive Policy: A firewall policy that allows network connections from source addresses appearing on a whitelist.
- Protocol: A special set of rules that devices in a telecommunication connection use when communicating with one another.
- Service: Functionality provided to network users that is of some utility, e.g., file storage, file transfer, browser access to an interface.
- Standard Allowed Ports: Ports that carry network traffic for defined services allowed by standards, e.g., port 443 for HTTPS, port 22 for SSH2, port 25 for SMTP.
- Standard: A rule that specifies a particular course of action or response to a given situation; standards are mandatory directives used to measure compliance with policies.
- Stateful Firewall Rules: A firewall that keeps track of the state of network connections and only allows packet streams that are part of an active connection to be delivered from the destination device to the device that initiated the conversation.
- Trusted Network: An internal network that resides behind a firewall.
- Trusted Link: A link within the Trusted Network.
- Virtual Routing & Forwarding (VRF): A technology allowing multiple instances of a routing table to exist and operate simultaneously in a router, segmenting network paths without multiple devices; also increases network security.
- Whitelisting: A firewall policy where communication from an approved list of network addresses is accepted, and all other connections are refused.
- Zone (Domain): Multiple interfaces with the same or similar security requirements that are logically grouped together.